

Bypass de UAC

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

El Control de Cuentas de Usuario (UAC) hace que, aunque tu usuario sea administrador, ejecutes con un token de integridad media hasta que confirmas la elevación. Un bypass de UAC aprovecha binarios de Windows que auto-elevan sin pedir consentimiento para lanzar un proceso con integridad alta (admin completo) sin el prompt.

Ciertos ejecutables firmados de Microsoft se auto-elevan y leen configuración del registro de usuario; si secuestras esa clave (fodhelper, eventvwr), Windows lanza tu comando elevado. No es cruzar de usuario a admin, sino de 'admin a medias' a 'admin completo'.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando `whoami /groups` muestra que estas en Administrators pero con integridad media (no puedes tocar recursos protegidos aun). No aplica si ya eres SYSTEM o integridad alta.

Cómo identificarla

- Estas en el grupo Administrators pero el nivel de integridad es Medium.
- Operaciones de admin fallan con acceso denegado pese a ser admin.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

`whoami /groups` | `findstr Label` para ver tu nivel de integridad actual.

Evidencia esperada: 'Mandatory Label\Medium'; tras el bypass, un proceso con integridad High ejecutando tu comando.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.

4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
whoami /groups | findstr /i "Label"
```

Objetivo y contexto: Muestra tu nivel de integridad (Mandatory Label). Distingue si necesitas bypass de UAC (Medium) o si ya tienes admin completo (High).

Resultado esperado: 'Mandatory Label\Medium' = necesitas UAC bypass. 'High' = ya elevado, no hace falta. Junto con el grupo Administrators define si aplica.

Capa 2: prueba documentada

```
reg add HKCU\Software\Classes\ms-settings\Shell\Open\command /d "cmd.exe" /f
```

Objetivo y contexto: Prepara el secuestro de fodhelper: al ejecutarse (auto-elevado), lee esta clave de usuario y lanza tu comando con integridad alta, sin prompt de UAC.

Resultado esperado: Tras esto, ejecutar fodhelper.exe abre un cmd elevado (integridad High). Ajusta la tecnica/clave a la build de Windows; limpia la clave despues.

Anatomía de los payloads

La primera prueba es `whoami /groups | findstr /i "Label"`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

'Mandatory Label\Medium'; tras el bypass, un proceso con integridad High ejecutando tu comando.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Confirma que eres admin con integridad media (`whoami /groups`).
- Elige una tecnica segun la build (`fodhelper`, `eventvwr`, `computerdefaults`).
- Secuestra la clave de registro correspondiente para que apunte a tu comando.
- Dispara el binario auto-elevado; tu comando corre con integridad alta.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- Tu usuario no esta en Administrators (esto no es una escalada de usuario a admin, solo de admin-medio a admin-alto).
- Ya tienes integridad High/System.

- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

Ya eres admin pero con token limitado; un bypass de UAC eleva a integridad alta sin el prompt de consentimiento. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y preconditiones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.

4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (uac-bypass)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.